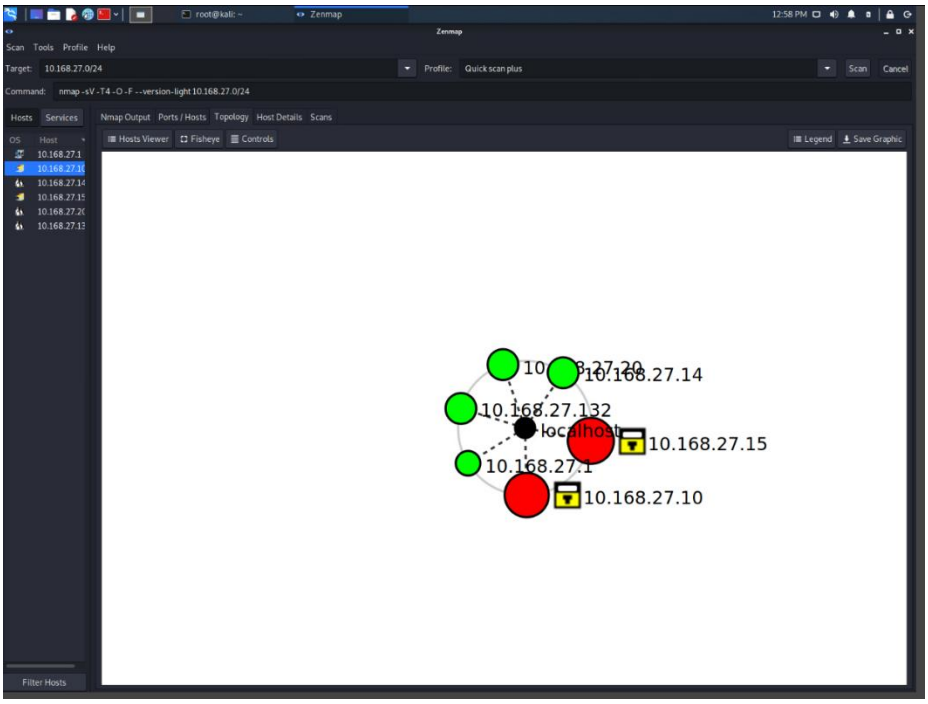
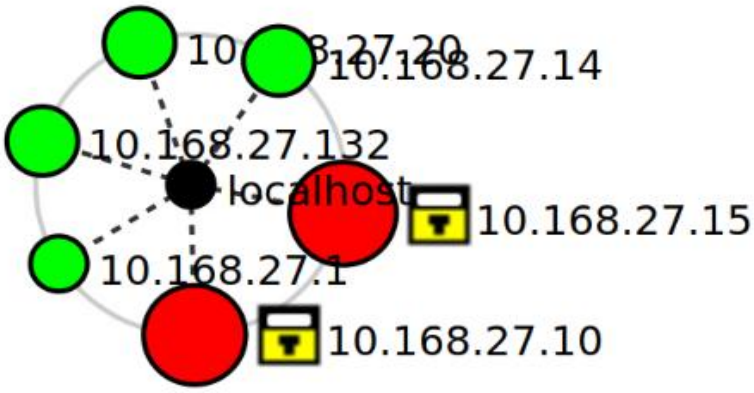
C844 Task 1

Below are the findings after performing an Nmap scan and Wireshark packet analysis of the given network.

NMAP:

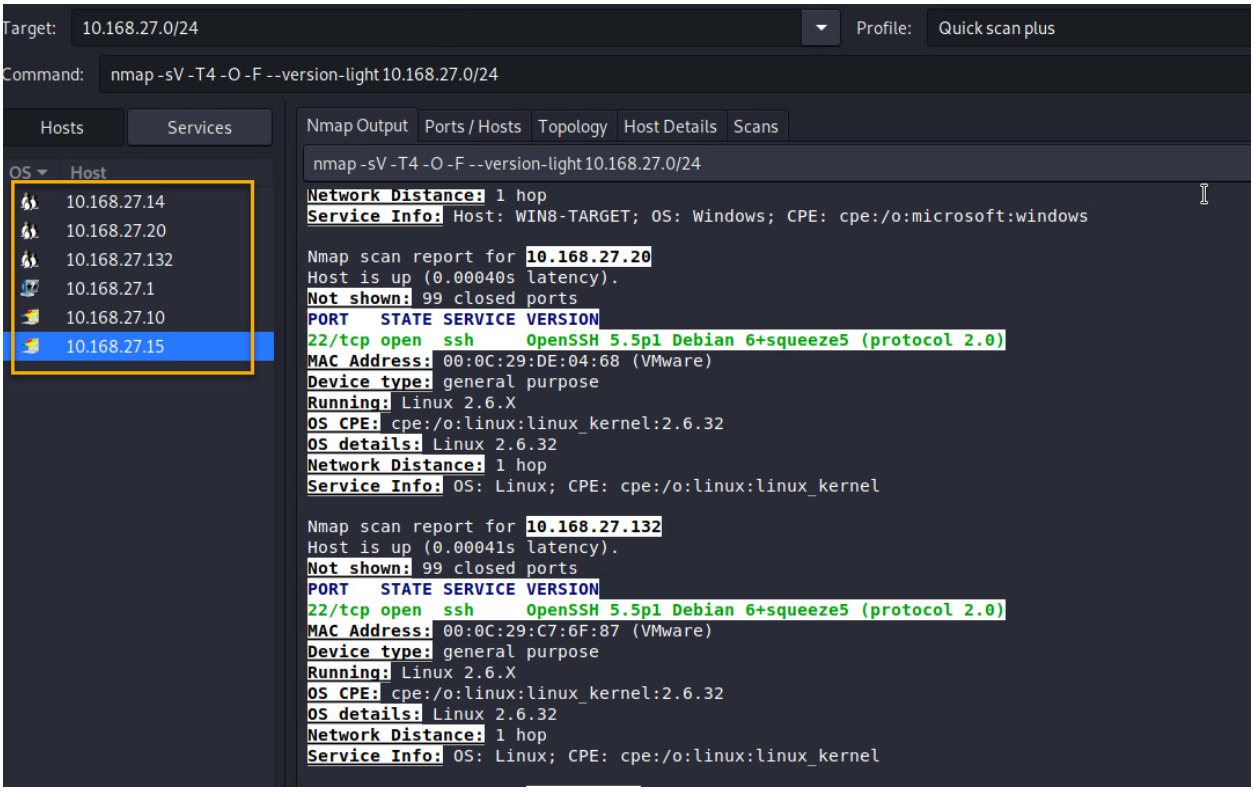
Based on the scan result from the Nmap output, we can see that the network is based on a star topology.

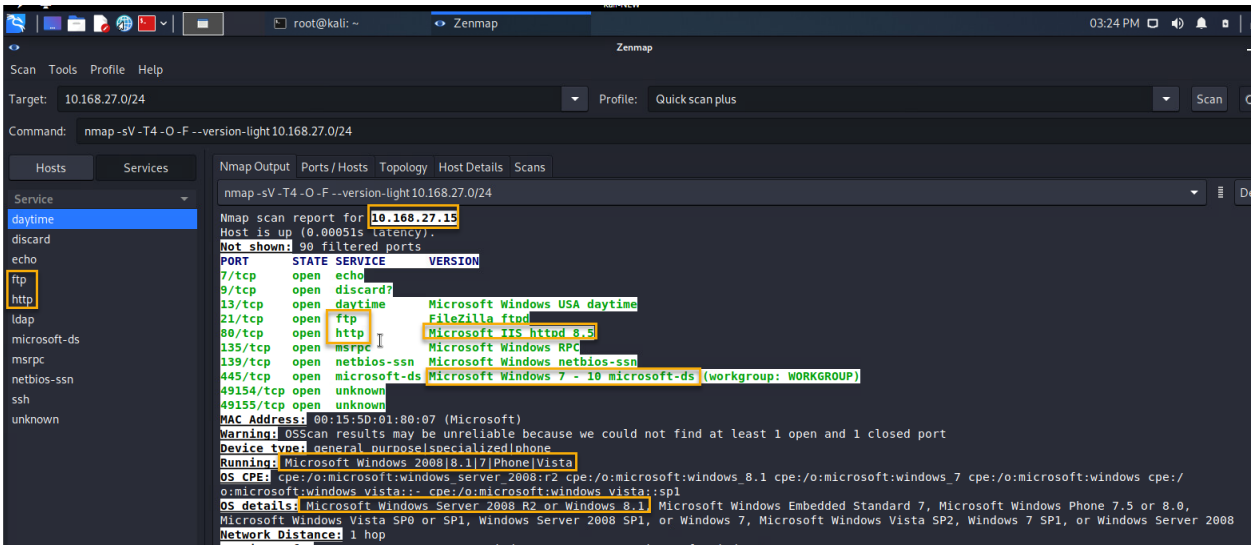




Each point in the topology was identified by the scan and referenced in the IP address list on the left-hand pane in the image below. In addition to the available host machines on the network, the

scan was able to identify several services available within the network. These include some unsecure or vulnerable protocols, unsupported operating systems, as well as application versions that are subject to exploitation.

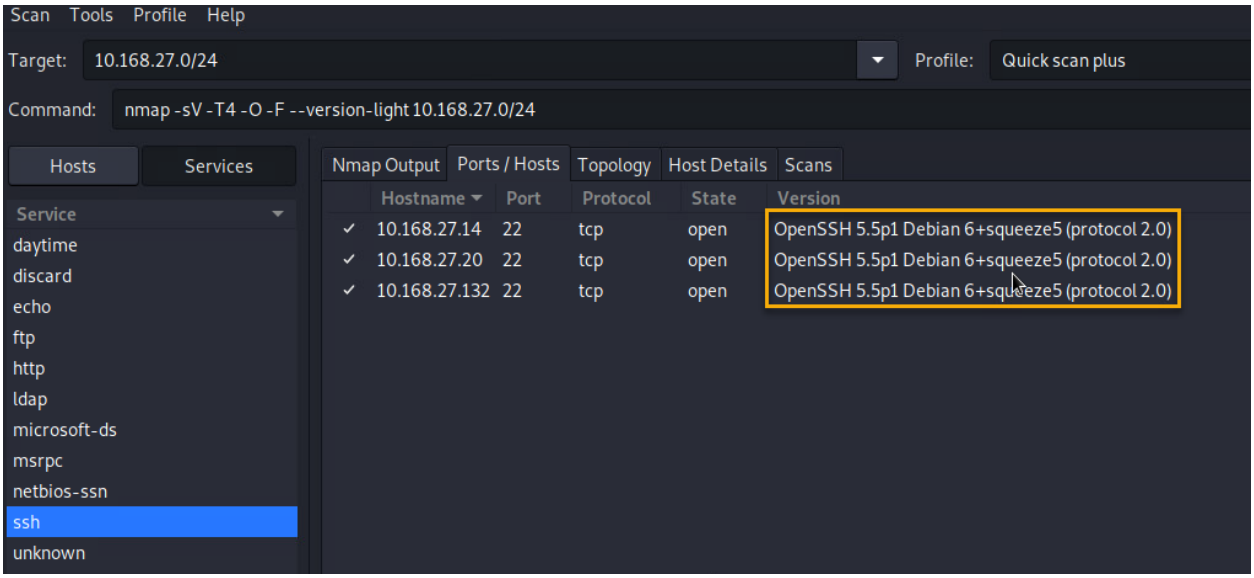




HTTP and FTP are both enabled and are vulnerable to interception and credential theft due to their unencrypted transmission of credentials in plaintext at the packet level.

This can be remediated by practicing IP whitelisting at the firewall as well as setting up the applicable site or application to communicate using a TLS encrypted form of the same protocols.

The Linux hosts on the network are seen to be open for port 22 traffic indicating the use of SSH or SFTP, however the library they are using for the session connections, OpenSSH 5.5p1, is noted as vulnerable to attack based on CVE-2015-5600 (Fortra Inc. 2024) The fix in this case is to update the OpenSSH library to any version after 7.0 or newer.

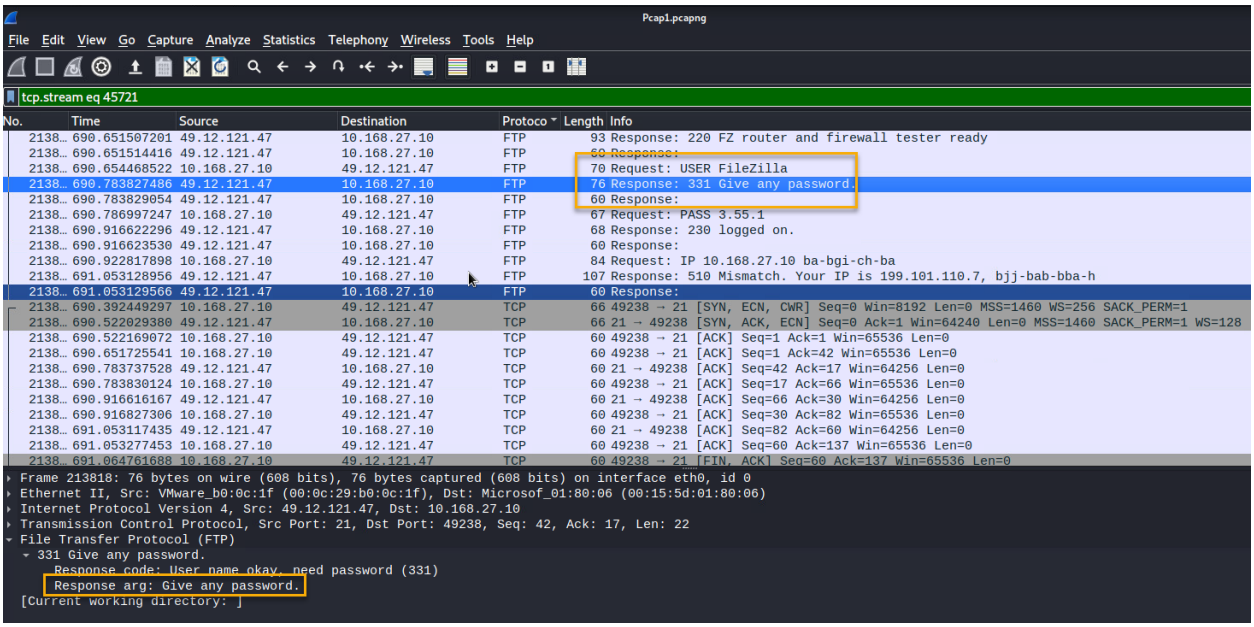


The Windows systems showing on the network are both running OS versions that are considered out of support for the OS vendor, Microsoft. (Microsoft, 2024) Once and Operating system or application reached the end of life or end of supported status, there are typically no further security or functional fixes released or developed. This inherent risk can be resolved by upgrading the OS versions to a modern release.

WIRESHARK:

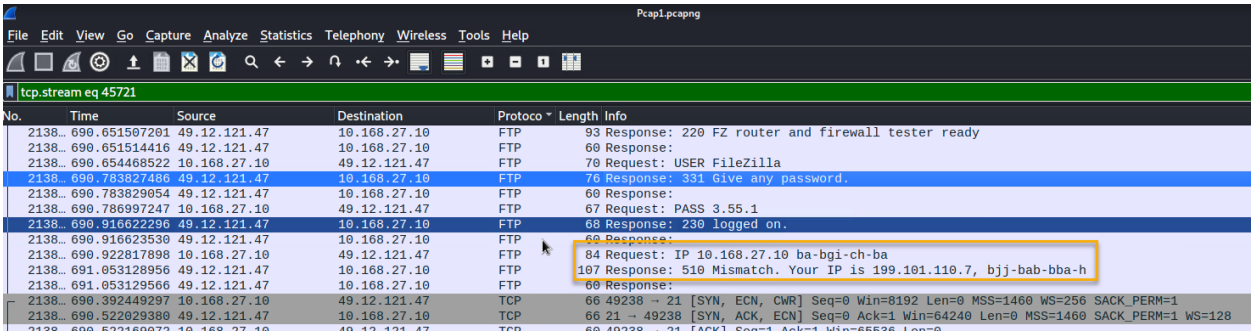
Using Pcap1.pcapng there are several identifiable vulnerabilities that warrant attention.

The first seen in the image below is the use of the FTP protocol without TLS encryption. This allows the transmission of usernames and passwords in plaintext.



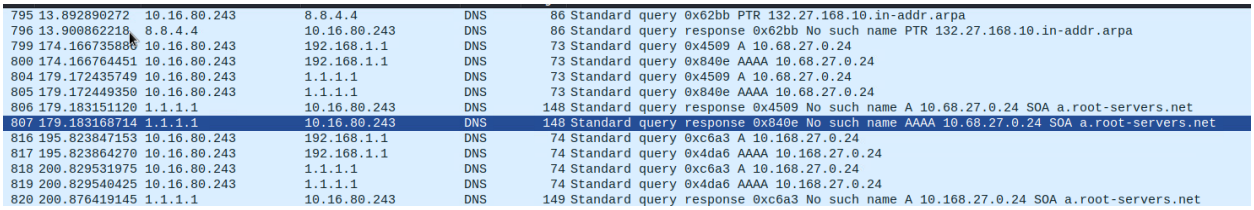
There are multiple ways to resolve this risky practice. One is to enable FTPS explicit or FTPS implicit to allow the traffic to be encrypted thus removing the ease of capture of a set of user credentials. Another would be to use a protocol that is secure by default. This would be SFTP or SSH and either will negotiate encryption without allowing the password of the user to be deciphered by any potential network eavesdropping.

A secondary concern is seen when looking at the TCP stream of this same FTP conversation between client and server, not only do the credentials appear in plain text, but it appears that there may be a successful man-in-the-middle attempt connected to the listening site as seen in this set of packets the client IP on the source remains 49.12.121.47, but with the response packet there is a flag identifying an alternate IP of 199.101.110.7.

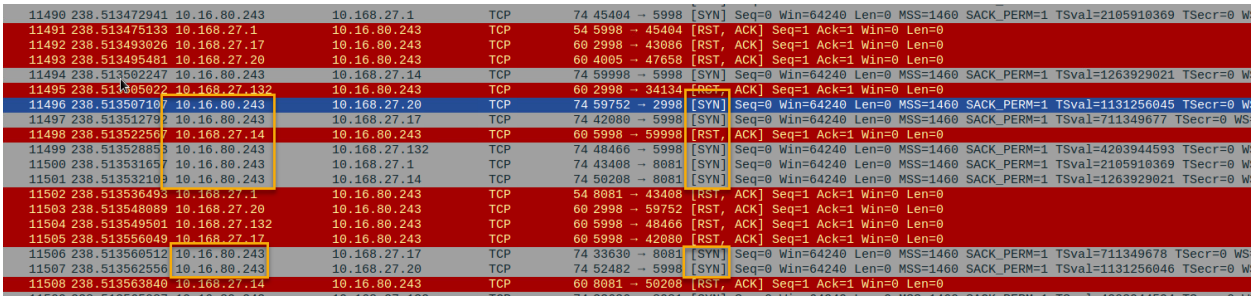


Hardening protocols on any sites as well as exercising IP whitelisting can have a beneficial impact on ensuring only authorized traffic is allowed to connect in and out of the network or server.

Additionally, there is a major concern in regards to IP 10.16.80.243. This IP can be witnessed querying DNS servers of various locations for FQDN information.

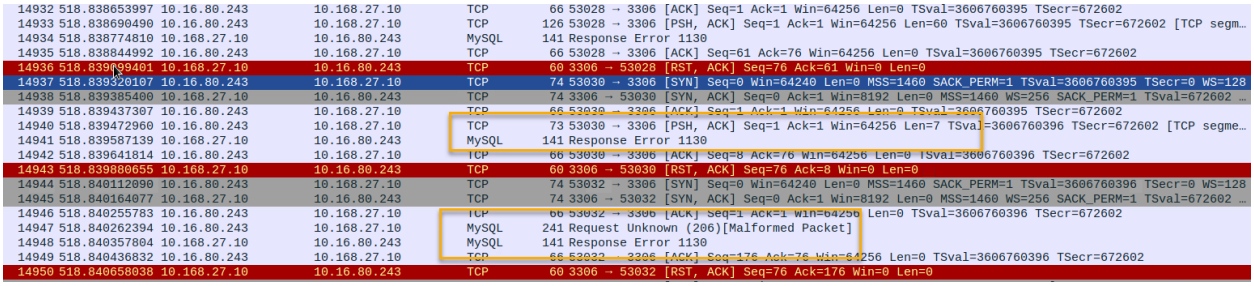


The suspect IP then moves on to spamming SYN packets to a number of internal IPs in the network:

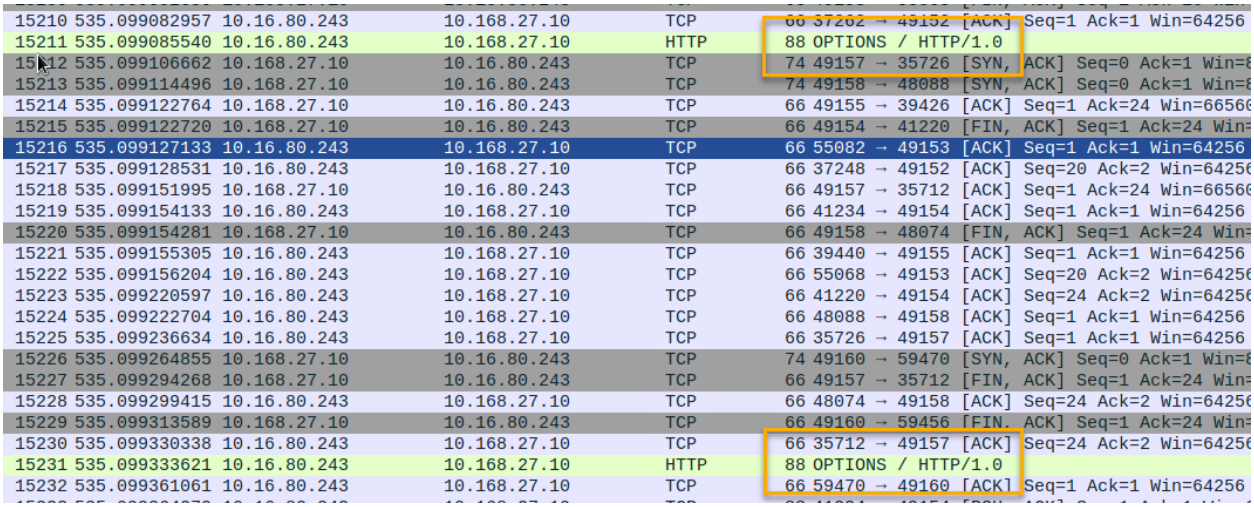


After finding IPs 10.168.27.132, 10.168.27.14, and 10.168.27.20 that respond, the IP is able to begin a kex negotiation to connect to the Linux servers identified in the NMAP running a vulnerable version of OpenSSH that can lead to brute force exploitations as well as DOS attacks.

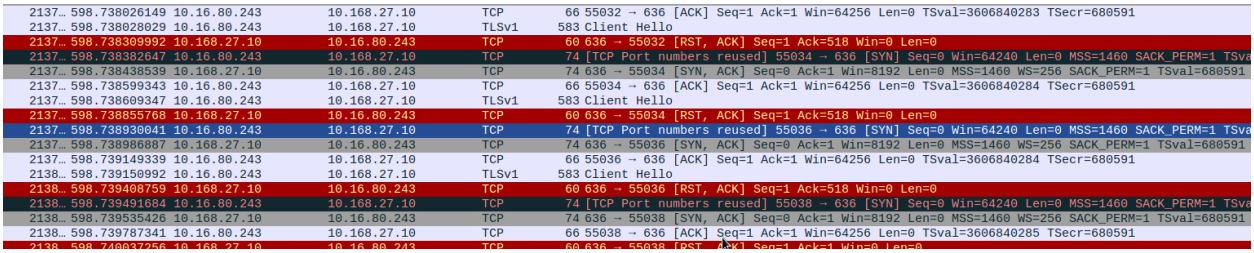
Continuing to follow the activity in the capture, we see the attack evolve into SQL injection or invocation events on a different IP in the network that responded to a syn packet, 10.168.27.10.



Followed by HTTP OPTIONS commands



This exploitation appears to culminate into the 10.168.27.10 address becoming unresponsive to any further requests.



The remediation here would need to be identifying what application or user is tied to the IP 10.16.80.243 and investigating hardening allowed protocols, IP white-lists, and segmented networking for different topographical resources. The addition of a responsive intrusion detection or Flood/Hammer protection can also help to address this type of exploit moving forward.

References

Fortra Inc. (2024, March 22). *OpenSSH version prior to 7.0 vulnerability scanner: Beyond security*. Vulnerability Security Testing & DAST | Beyond Security. https://www.beyondsecurity.com/resources/vulnerabilities/openssh-running-version-prior-7-0

Ending support in 2024 - Microsoft lifecycle. Microsoft Lifecycle | Microsoft Learn. (2024, July 31). https://learn.microsoft.com/en-us/lifecycle/end-of-support/end-of-support-2024